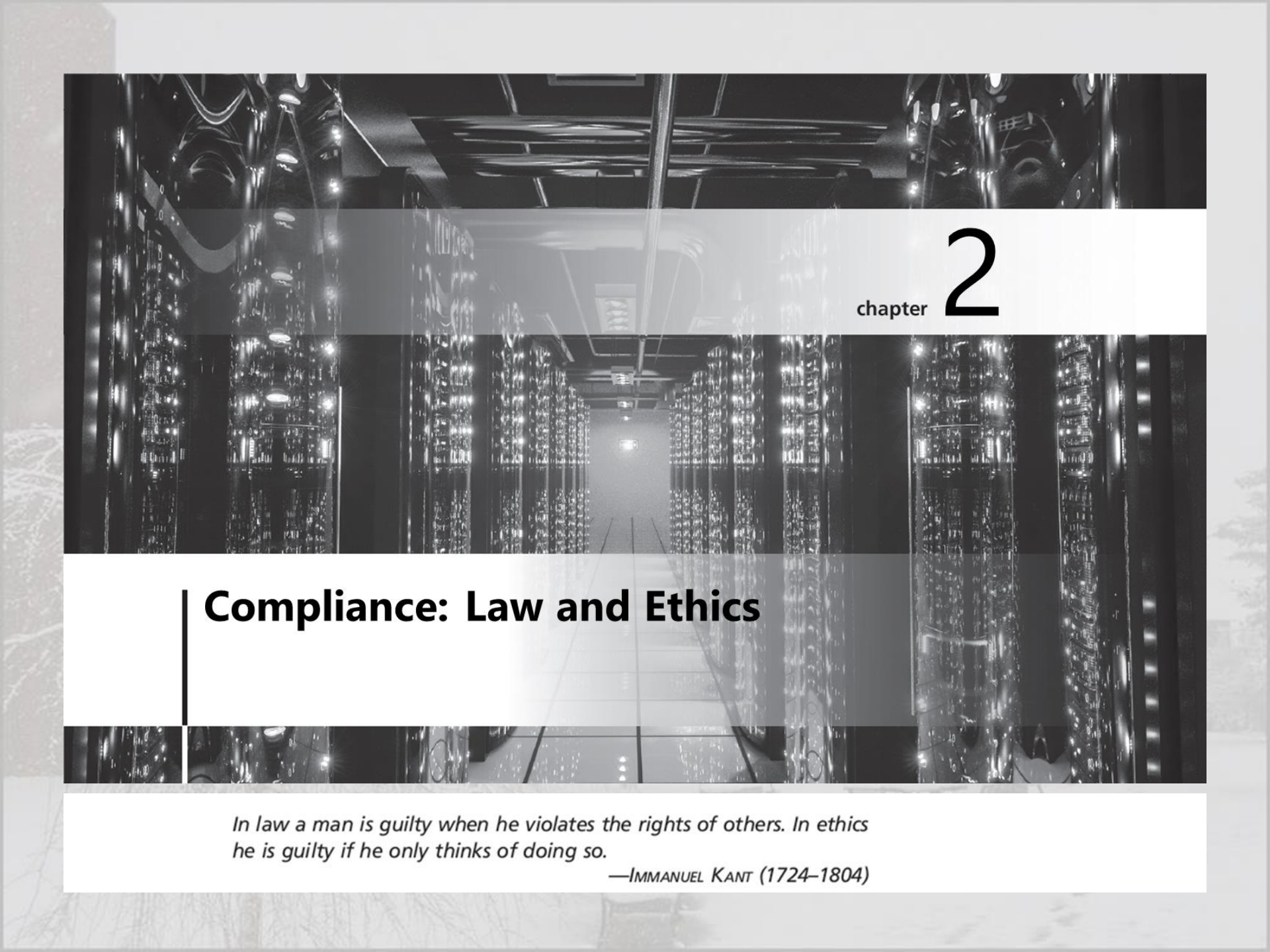




chapter 2

Compliance: Law and Ethics

In law a man is guilty when he violates the rights of others. In ethics he is guilty if he only thinks of doing so.

—IMMANUEL KANT (1724–1804)

The background image is a faded, grayscale photograph of a modern architectural complex. A large, multi-story building with a curved facade and large glass windows is the central focus. In the foreground, there is a park-like area with a prominent weeping willow tree on the left, its branches hanging down. Several outdoor tables and chairs are arranged in the middle ground, and a paved path leads towards the building. The overall atmosphere is quiet and academic.

Luật và Quy định

Case Opener

Iris was just over halfway through her usual morning e-mail ritual when she came to a message that caught her attention. Just a few weeks before, Random Widget Works, Inc. (RWW) had set up a new customer feedback Web server to facilitate open dialog and unrestricted feedback. This system would allow anyone, anywhere to send anonymous e-mail to the company's most senior executive. Apparently, someone had sent just such a message, and the CEO's executive assistant had relayed it to Iris. The e-mail read as follows:

To: Iris Majwubu

From: Cassandra Wilmington, Special Assistant to the CEO

Date: 2018-11-18 07:45 AM

Subject: FW: Anonymous Ethics Report — 2018-11-17 07:46 AM

Iris, you better look at this. The attached message came in on the anonymous customer feedback system. I captured the text, encrypted it and have attached it to this e-mail. The boss has already seen it and asked me to distribute secure copies to you as well as Robin, Jerry, and Mike. He already has a meeting with Mike set for this morning at 10:00. You and the others should be there, too. A meeting invitation follows. . .

Iris opened her safe, retrieved and mounted her secure document drive, then exported the attachment file to it. She opened the decryption program, swiping her employee ID keycard and typing her personal identification number (PIN) to decrypt the message. The text appeared:

To: RWW Anonymous Feedback Mailbox

From: A Friend

Date: 2018-11-14 02:46 AM

Subject: RWW is for sale

You might want to look at the everythingz4zale.com auction site at www.everythingz4zale.com/auctions/ref=19085769340

Iris opened her browser window and typed in the URL. She saw:

Item #19085769340

RWW, Inc. Customer and key accounts list

Starting bid: US \$10,000.00

Time left: 1 day 22 hours 50 mins 3-day listing

History: 0 bids

Location: Cityville, WI

Iris picked up her phone and dialed RWW's legal affairs office. She knew it was going to be a busy day.

Giới thiệu

- Chuyên gia bảo mật thông tin được yêu cầu phải hiểu phạm vi trách nhiệm pháp lý và đạo đức của tổ chức
- Để giảm thiểu trách nhiệm pháp lý của tổ chức, người hành nghề an toàn thông tin phải hiểu môi trường pháp lý hiện tại và tuân thủ các luật, quy định mới và các vấn đề đạo đức
- Bằng cách giáo dục nhân viên và cấp quản lý về các nghĩa vụ pháp lý và đạo đức của họ cũng như việc sử dụng công nghệ thông tin và bảo mật thông tin một cách hợp lý, các chuyên gia bảo mật có thể giữ cho **tổ chức tập trung vào các mục tiêu chính** của mình

Giới thiệu

- Các chuyên gia và người quản lý ATTT bảo đảm ATTT phải nằm được khung pháp lý mà tổ chức của họ đang làm việc
- Môi trường pháp lý ảnh hưởng đến hành vi của mọi tổ chức tùy thuộc vào bản chất của tổ chức và quy mô mà tổ chức đó hoạt động
- Cấp quản lý, nhất là các chuyên gia ATTT, phải tuân thủ các yêu cầu pháp lý khi thu thập, lưu trữ và sử dụng thông tin

The background image is a faded, grayscale photograph of a modern architectural complex. A large, multi-story building with a curved facade and large glass windows is the central focus. In the foreground, there is a park-like area with a prominent weeping willow tree on the left, its branches hanging down. Several outdoor tables and chairs are arranged in the middle ground, and a paved path leads towards the building. The overall atmosphere is calm and institutional.

Luật Việt Nam về ATTT

Hệ thống Pháp luật Việt Nam

- Hệ thống pháp luật Việt Nam là tổng thể các quy phạm pháp luật, các nguyên tắc, định hướng và mục đích của pháp luật có mối liên hệ mật thiết và thống nhất với nhau, được phân định thành các ngành luật, các chế định pháp luật và được thể hiện trong các văn bản do cơ quan nhà nước Việt Nam có thẩm quyền ban hành theo những hình thức, thủ tục nhất định để điều chỉnh các quan hệ xã hội phát sinh trên lãnh thổ Việt Nam.
- Hệ thống văn bản pháp luật của Việt Nam bao gồm:
 - **Hiến pháp**: Do Quốc hội ban hành, là văn bản pháp luật cao nhất
 - **Luật** hoặc **Bộ Luật**: Do Quốc hội thông qua và Chủ tịch nước ký quyết định ban hành. Trong lĩnh vực an toàn an ninh mạng có Luật An toàn thông tin mạng 2015 và Luật An ninh mạng 2018
 - **Nghị quyết** của Quốc hội
 - Văn bản dưới luật gồm:
 - + Pháp lệnh, Nghị quyết của Ủy ban Thường vụ Quốc hội
 - + Lệnh, Quyết định của Chủ tịch nước
 - + Nghị định của Chính phủ
 - + Quyết định của Thủ tướng Chính phủ
 - + Thông tư của Bộ trưởng, thủ trưởng cơ quan ngang bộ, Chánh án tòa án nhân dân tối cao, Viện trưởng Viện kiểm sát nhân dân tối cao

Luật hiện hành về ATTT

Luật An toàn thông tin mạng (86/2015/QH13)

Quy định về hoạt động an toàn thông tin mạng, quyền, trách nhiệm của cơ quan, tổ chức, cá nhân trong việc bảo đảm an toàn thông tin mạng; mật mã dân sự; tiêu chuẩn, quy chuẩn kỹ thuật về an toàn thông tin mạng; kinh doanh trong lĩnh vực an toàn thông tin mạng; phát triển nguồn nhân lực an toàn thông tin mạng; quản lý nhà nước về an toàn thông tin mạng

Luật An ninh mạng (24/2018/QH14)

Quy định về hoạt động bảo vệ an ninh quốc gia và bảo đảm trật tự, an toàn xã hội trên không gian mạng; trách nhiệm của cơ quan, tổ chức, cá nhân có liên quan

Luật mới về An ninh mạng

Luật An ninh mạng (116/2025/QH15)

- Quy định về an ninh mạng; bảo vệ an ninh mạng; quyền, nghĩa vụ, trách nhiệm của cơ quan, tổ chức, cá nhân có liên quan.
- Hiệu lực từ 1/7/2026

Luật An toàn thông tin mạng

Điều 7: Các hành vi bị **ng nghiêm cấm**

1. **Ngăn chặn** việc truyền tải thông tin trên mạng, can thiệp, truy nhập, gây nguy hại, **xóa, thay đổi, sao chép và làm sai lệch thông tin** trên mạng trái pháp luật.
2. Gây ảnh hưởng, **cản trở trái pháp luật tới hoạt động bình thường** của hệ thống thông tin hoặc tới khả năng truy nhập hệ thống thông tin của người sử dụng.
3. Tấn công, **vô hiệu hóa trái pháp luật làm mất tác dụng của biện pháp bảo vệ** an toàn thông tin mạng của hệ thống thông tin; tấn công, chiếm quyền điều khiển, phá hoại hệ thống thông tin.
4. **Phát tán thư rác**, phần mềm độc hại, thiết lập hệ thống thông tin giả mạo, lừa đảo.
5. Thu thập, sử dụng, phát tán, **kinh doanh trái pháp luật thông tin cá nhân** của người khác; lợi dụng sơ hở, điểm yếu của hệ thống thông tin để thu thập, khai thác thông tin cá nhân.
6. **Xâm nhập trái pháp luật bí mật mật mã và thông tin đã mã hóa hợp pháp** của cơ quan, tổ chức, cá nhân; tiết lộ thông tin về sản phẩm mật mã dân sự, thông tin về khách hàng sử dụng hợp pháp sản phẩm mật mã dân sự; **sử dụng, kinh doanh các sản phẩm mật mã dân sự không rõ nguồn gốc**.

Luật An toàn thông tin mạng

Điều 8. Xử lý vi phạm pháp luật về an toàn thông tin mạng

1. Người nào có hành vi vi phạm quy định của Luật này thì tùy theo tính chất, mức độ vi phạm mà bị xử lý kỷ luật, xử phạt vi phạm hành chính hoặc bị truy cứu **trách nhiệm hình sự**; nếu gây thiệt hại thì phải bồi thường theo quy định của pháp luật.

Điều 10. Quản lý gửi thông tin

1. Việc gửi thông tin trên mạng phải bảo đảm các yêu cầu sau đây:
 - a) **Không giả mạo nguồn gốc** gửi thông tin;
 - b) Tuân thủ quy định của Luật này và quy định khác của pháp luật có liên quan.
2. Tổ chức, cá nhân **không được gửi thông tin mang tính thương mại vào địa chỉ điện tử của người tiếp nhận khi chưa được người tiếp nhận đồng ý** hoặc khi người tiếp nhận đã từ chối, trừ trường hợp người tiếp nhận có nghĩa vụ phải tiếp nhận thông tin theo quy định của pháp luật.

Luật An toàn thông tin mạng

Điều 11. Phòng ngừa, phát hiện, ngăn chặn và xử lý phần mềm độc hại

1. Cơ quan, tổ chức, cá nhân có **trách nhiệm** thực hiện phòng ngừa, ngăn chặn phần mềm độc hại **theo hướng dẫn, yêu cầu của cơ quan nhà nước** có thẩm quyền.

Điều 12. Bảo đảm an toàn tài nguyên viễn thông

1. Cơ quan, tổ chức, cá nhân sử dụng tài nguyên viễn thông có trách nhiệm sau đây:
 - a) Áp dụng biện pháp quản lý và kỹ thuật để ngăn chặn mất an toàn thông tin mạng xuất phát từ **tần số, kho số, tên miền và địa chỉ Internet** của mình;
 - b) Phối hợp, **cung cấp thông tin** liên quan đến an toàn tài nguyên viễn thông **theo yêu cầu của cơ quan nhà nước** có thẩm quyền.

Luật An toàn thông tin mạng

Điều 15. Trách nhiệm của cơ quan, tổ chức, cá nhân trong bảo đảm an toàn thông tin mạng

1. Cơ quan, tổ chức, cá nhân tham gia hoạt động an toàn thông tin mạng có **trách nhiệm phối hợp với cơ quan nhà nước** có thẩm quyền và tổ chức, cá nhân khác trong việc bảo đảm an toàn thông tin mạng.
2. Cơ quan, tổ chức, cá nhân sử dụng dịch vụ trên mạng có **trách nhiệm thông báo kịp thời cho doanh nghiệp** cung cấp dịch vụ hoặc bộ phận chuyên trách ứng cứu sự cố **khi phát hiện các hành vi phá hoại hoặc sự cố an toàn thông tin mạng**.

Luật An toàn thông tin mạng

Điều 17. Thu thập và sử dụng thông tin cá nhân

1. Tổ chức, cá nhân xử lý thông tin cá nhân có trách nhiệm sau đây:
 - a) Tiến hành thu thập thông tin cá nhân sau khi **có sự đồng ý của chủ thể** thông tin cá nhân về phạm vi, mục đích của việc thu thập và sử dụng thông tin đó;
 - b) Chỉ sử dụng thông tin cá nhân đã thu thập vào mục đích khác mục đích ban đầu sau khi **có sự đồng ý** của chủ thể thông tin cá nhân;
 - c) **Không được cung cấp, chia sẻ, phát tán** thông tin cá nhân mà mình đã thu thập, tiếp cận, kiểm soát **cho bên thứ ba**, trừ trường hợp có sự đồng ý của chủ thể thông tin cá nhân đó hoặc theo yêu cầu của cơ quan nhà nước có thẩm quyền.
2. Cơ quan nhà nước chịu trách nhiệm bảo mật, lưu trữ thông tin cá nhân do mình thu thập.
3. **Chủ thể** thông tin cá nhân có quyền **yêu cầu tổ chức, cá nhân xử lý thông tin cá nhân cung cấp thông tin cá nhân của mình** mà tổ chức, cá nhân đó đã thu thập, lưu trữ.

Luật An toàn thông tin mạng

Điều 18. Cập nhật, sửa đổi và hủy bỏ thông tin cá nhân

1. Chủ thể thông tin cá nhân có quyền yêu cầu tổ chức, cá nhân xử lý thông tin cá nhân cập nhật, sửa đổi, hủy bỏ thông tin cá nhân của mình mà tổ chức, cá nhân đó đã thu thập, lưu trữ hoặc ngừng cung cấp thông tin cá nhân của mình cho bên thứ ba.

Điều 19. Bảo đảm an toàn thông tin cá nhân trên mạng

1. Tổ chức, cá nhân xử lý thông tin cá nhân phải áp dụng biện pháp quản lý, kỹ thuật phù hợp để bảo vệ thông tin cá nhân do mình thu thập, lưu trữ; tuân thủ các tiêu chuẩn, quy chuẩn kỹ thuật về bảo đảm an toàn thông tin mạng.
2. Khi xảy ra hoặc có nguy cơ xảy ra sự cố an toàn thông tin mạng, tổ chức, cá nhân xử lý thông tin cá nhân cần áp dụng biện pháp khắc phục, ngăn chặn trong thời gian sớm nhất.

Luật An toàn thông tin mạng

Điều 28. Trách nhiệm của tổ chức, cá nhân trong việc ngăn chặn xung đột thông tin trên mạng

1. Tổ chức, cá nhân trong phạm vi nhiệm vụ, quyền hạn của mình có trách nhiệm sau đây:
 - a) **Ngăn chặn thông tin phá hoại** xuất phát từ hệ thống thông tin của mình; **hợp tác xác định nguồn, đẩy lùi, khắc phục hậu quả tấn công mạng** được thực hiện thông qua hệ thống thông tin của tổ chức, cá nhân trong nước và nước ngoài;
 - b) **Ngăn chặn hành động của tổ chức**, cá nhân trong nước và nước ngoài có mục đích phá hoại tính nguyên vẹn của mạng;
 - c) Loại trừ việc tổ chức thực hiện hoạt động trái pháp luật trên mạng có **ảnh hưởng nghiêm trọng đến quốc phòng, an ninh quốc gia, trật tự, an toàn xã hội** của tổ chức, cá nhân trong nước và nước ngoài.

Luật An toàn thông tin mạng

Điều 29. Ngăn chặn hoạt động sử dụng mạng để khủng bố

1. Các biện pháp ngăn chặn hoạt động sử dụng mạng để khủng bố gồm:
 - a) Vô hiệu hóa nguồn Internet sử dụng để thực hiện hành vi khủng bố;
 - b) Ngăn chặn việc thiết lập và mở rộng trao đổi thông tin về các tín hiệu, nhân tố, phương pháp và cách sử dụng Internet để thực hiện hành vi khủng bố, về mục tiêu và hoạt động của các tổ chức khủng bố trên mạng;
 - c) Trao đổi kinh nghiệm và thực tiễn kiểm soát các nguồn Internet, tìm và kiểm soát nội dung của trang tin điện tử có mục đích khủng bố.

Luật An ninh mạng

Điều 4. Nguyên tắc bảo vệ an ninh mạng

1. Kết hợp chặt chẽ giữa nhiệm vụ bảo vệ an ninh mạng, bảo vệ hệ thống thông tin quan trọng về an ninh quốc gia với nhiệm vụ phát triển kinh tế - xã hội, **bảo đảm quyền con người, quyền công dân, tạo điều kiện cho cơ quan, tổ chức, cá nhân hoạt động trên không gian mạng.**
2. Chủ động phòng ngừa, phát hiện, ngăn chặn, đấu tranh, làm thất bại mọi hoạt động sử dụng không gian mạng **xâm phạm an ninh quốc gia, trật tự, an toàn xã hội, quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân;** sẵn sàng ngăn chặn các nguy cơ đe dọa an ninh mạng.
3. Triển khai hoạt động bảo vệ an ninh mạng đối với cơ sở hạ tầng không gian mạng quốc gia; **áp dụng các biện pháp bảo vệ hệ thống thông tin quan trọng về an ninh quốc gia.**

Luật An ninh mạng

Điều 8. Các hành vi bị nghiêm cấm về an ninh mạng

1. Sử dụng không gian mạng để thực hiện hành vi sau đây:

- a) Hành vi quy định tại khoản 1 Điều 18 của Luật này;
- b) Tổ chức, hoạt động, **câu kết, xúi giục, mua chuộc, lừa gạt, lôi kéo**, đào tạo, huấn luyện người chống Nhà nước Cộng hòa xã hội chủ nghĩa Việt Nam;
- c) **Xuyên tạc lịch sử**, phủ nhận thành tựu cách mạng, phá hoại khối đại đoàn kết toàn dân tộc, xúc phạm tôn giáo, phân biệt đối xử về giới, phân biệt chủng tộc;
- d) **Thông tin sai sự thật** gây hoang mang trong Nhân dân, gây thiệt hại cho hoạt động kinh tế - xã hội, gây khó khăn cho hoạt động của cơ quan nhà nước hoặc người thi hành công vụ, xâm phạm quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân khác;
- e) **Hoạt động mại dâm, tệ nạn xã hội**, mua bán người; đăng tải thông tin dâm ô, đồi trụy, tội ác; phá hoại thuần phong, mỹ tục của dân tộc, đạo đức xã hội, sức khỏe của cộng đồng;
- f) **Xúi giục, lôi kéo, kích động** người khác phạm tội.

Luật An ninh mạng

Điều 8. Các hành vi bị nghiêm cấm về an ninh mạng

2. Thực hiện **tấn công mạng, khủng bố mạng, gián điệp mạng, tội phạm mạng**; gây sự cố, tấn công, xâm nhập, chiếm quyền điều khiển, làm sai lệch, gián đoạn, ngưng trệ, tê liệt hoặc phá hoại hệ thống thông tin quan trọng về an ninh quốc gia.
3. Sản xuất, đưa vào sử dụng công cụ, phương tiện, phần mềm hoặc có hành vi cản trở, gây rối loạn hoạt động của mạng viễn thông, mạng Internet, mạng máy tính, hệ thống thông tin, hệ thống xử lý và điều khiển thông tin, phương tiện điện tử (**M**); **phát tán** chương trình tin học gây hại cho hoạt động của M; **xâm nhập trái phép** vào M, cơ sở dữ liệu của người khác.
4. **Chống lại hoặc cản trở** hoạt động của lực lượng **bảo vệ an ninh mạng**; tấn công, vô hiệu hóa trái pháp luật làm mất tác dụng biện pháp bảo vệ an ninh mạng.
5. Lợi dụng hoặc lạm dụng hoạt động bảo vệ an ninh mạng để **xâm phạm chủ quyền**, lợi ích, an ninh quốc gia, trật tự, an toàn xã hội, quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân hoặc để trục lợi.

Luật An ninh mạng

Điều 9. Xử lý vi phạm pháp luật về an ninh mạng

1. Người nào có hành vi vi phạm quy định của Luật này thì tùy theo tính chất, mức độ vi phạm mà bị xử lý kỷ luật, xử lý vi phạm hành chính hoặc bị truy cứu **trách nhiệm hình sự**, nếu gây thiệt hại thì phải bồi thường theo quy định của pháp luật.

Luật An ninh mạng

Điều 16. Phòng ngừa, xử lý thông tin trên không gian mạng có nội dung tuyên truyền chống Nhà nước Cộng hòa xã hội chủ nghĩa Việt Nam; kích động gây bạo loạn, phá rối an ninh, gây rối trật tự công cộng; làm nhục, vu khống; xâm phạm trật tự quản lý kinh tế

1. Thông tin trên không gian mạng có nội dung **tuyên truyền chống Nhà nước Cộng hòa xã hội chủ nghĩa Việt Nam** bao gồm:
 - a) **Tuyên truyền xuyên tạc, phỉ báng** chính quyền nhân dân;
 - b) Chiến tranh tâm lý, **kích động chiến tranh xâm lược**, chia rẽ, gây thù hận giữa các dân tộc, tôn giáo và nhân dân các nước;
 - c) **Xúc phạm dân tộc, quốc kỳ, quốc huy, quốc ca**, vĩ nhân, lãnh tụ, danh nhân, anh hùng dân tộc.
2. Thông tin trên không gian mạng có nội dung kích động **gây bạo loạn, phá rối** an ninh, gây rối trật tự công cộng bao gồm:
 - a) **Kêu gọi, vận động, xúi giục, đe dọa, gây chia rẽ**, tiến hành hoạt động vũ trang hoặc dùng bạo lực nhằm chống chính quyền nhân dân;
 - b) Kêu gọi, vận động, xúi giục, đe dọa, **lôi kéo tụ tập đông người gây rối, chống người thi hành công vụ**, cản trở hoạt động của cơ quan, tổ chức gây mất ổn định về an ninh, trật tự.

Luật An ninh mạng

Điều 16. Phòng ngừa, xử lý thông tin trên không gian mạng có nội dung tuyên truyền chống Nhà nước Cộng hòa xã hội chủ nghĩa Việt Nam; kích động gây bạo loạn, phá rối an ninh, gây rối trật tự công cộng; làm nhục, vu khống; xâm phạm trật tự quản lý kinh tế

3. Thông tin trên không gian mạng có nội dung **làm nhục, vu khống** bao gồm:

- a) **Xúc phạm nghiêm trọng danh dự**, uy tín, nhân phẩm của người khác;
- b) **Thông tin bịa đặt, sai sự thật** xâm phạm danh dự, uy tín, nhân phẩm hoặc gây thiệt hại đến quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân khác.

4. Thông tin trên không gian mạng có nội dung **xâm phạm trật tự** quản lý kinh tế bao gồm:

- a) **Thông tin bịa đặt, sai sự thật về sản phẩm, hàng hóa**, tiền, trái phiếu, tín phiếu, công trái, séc và các loại giấy tờ có giá khác;
- b) **Thông tin bịa đặt, sai sự thật trong lĩnh vực tài chính, ngân hàng**, thương mại điện tử, thanh toán điện tử, kinh doanh tiền tệ, huy động vốn, kinh doanh đa cấp, chứng khoán.

Luật An ninh mạng

Điều 16. Phòng ngừa, xử lý thông tin trên không gian mạng có nội dung tuyên truyền chống Nhà nước Cộng hòa xã hội chủ nghĩa Việt Nam; kích động gây bạo loạn, phá rối an ninh, gây rối trật tự công cộng; làm nhục, vu khống; xâm phạm trật tự quản lý kinh tế

5. Thông tin trên không gian mạng có nội dung **bịa đặt, sai sự thật gây hoang mang trong Nhân dân, gây thiệt hại cho hoạt động kinh tế - xã hội**, gây khó khăn cho hoạt động của cơ quan nhà nước hoặc người thi hành công vụ, xâm phạm quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân khác.
6. Tổ chức, cá nhân soạn thảo, đăng tải, phát tán thông tin trên không gian mạng có nội dung quy định tại các khoản 1, 2, 3, 4 và 5 Điều này phải **gỡ bỏ thông tin khi có yêu cầu của lực lượng chuyên trách** bảo vệ an ninh mạng và chịu trách nhiệm theo quy định của pháp luật.

Luật An ninh mạng

Điều 17. Phòng, chống gián điệp mạng; bảo vệ thông tin thuộc bí mật nhà nước, bí mật công tác, bí mật kinh doanh, bí mật cá nhân, bí mật gia đình và đời sống riêng tư trên không gian mạng

- 1. Hành vi** gián điệp mạng; xâm phạm bí mật nhà nước, bí mật công tác,... bao gồm:
 - a) **Chiếm đoạt, mua bán, thu giữ, cố ý làm lộ thông tin** thuộc bí mật nhà nước, bí mật công tác, bí mật kinh doanh, bí mật cá nhân, bí mật gia đình và đời sống riêng tư gây ảnh hưởng đến danh dự, uy tín, nhân phẩm, quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân;
 - b) **Cố ý xóa, làm hư hỏng, thất lạc, thay đổi thông tin** thuộc bí mật nhà nước, bí mật công tác, bí mật kinh doanh, bí mật cá nhân, bí mật gia đình và đời sống riêng tư được truyền đưa, lưu trữ trên không gian mạng;
 - c) **Cố ý thay đổi, hủy bỏ hoặc làm vô hiệu hóa biện pháp kỹ thuật** được xây dựng, áp dụng để bảo vệ thông tin thuộc bí mật nhà nước, bí mật công tác, bí mật kinh doanh, bí mật cá nhân, bí mật gia đình và đời sống riêng tư;
 - d) **Đưa lên không gian mạng những thông tin thuộc bí mật nhà nước**, bí mật công tác, bí mật kinh doanh, bí mật cá nhân, bí mật gia đình và đời sống riêng tư trái quy định của pháp luật;
 - đ) **Cố ý nghe, ghi âm, ghi hình trái phép** các cuộc đàm thoại;

Luật An ninh mạng

Điều 18. Phòng, chống hành vi sử dụng không gian mạng, công nghệ thông tin, phương tiện điện tử để vi phạm pháp luật về an ninh quốc gia, trật tự, an toàn xã hội

1. Hành vi sử dụng không gian mạng ...để vi phạm pháp luật về an ninh quốc gia, trật tự, an toàn xã hội bao gồm:

- a) **Đăng tải, phát tán thông tin** trên không gian mạng có nội dung quy định tại các khoản 1, 2, 3, 4 và 5 Điều 16 và hành vi quy định tại khoản 1 Điều 17 của Luật này;
- b) **Chiếm đoạt tài sản; tổ chức đánh bạc, đánh bạc qua mạng Internet**; trộm cắp cước viễn thông quốc tế trên nền Internet; vi phạm bản quyền và sở hữu trí tuệ trên không gian mạng;
- c) **Giả mạo trang thông tin điện tử** của cơ quan, tổ chức, cá nhân; làm giả, lưu hành, trộm cắp, mua bán, thu thập, trao đổi trái phép thông tin thẻ tín dụng, tài khoản ngân hàng của người khác; phát hành, cung cấp, sử dụng trái phép các phương tiện thanh toán;
- d) **Tuyên truyền, quảng cáo, mua bán hàng hóa, dịch vụ thuộc danh mục cấm** theo quy định của pháp luật;
- đ) **Hướng dẫn người khác** thực hiện hành vi vi phạm pháp luật;

Luật An ninh mạng

Điều 19. Phòng, chống tấn công mạng

1. **Hành vi** tấn công mạng và hành vi có liên quan đến tấn công mạng **bao gồm**:
 - a) **Phát tán chương trình tin học gây hại** cho mạng viễn thông, mạng Internet, mạng máy tính, hệ thống thông tin, hệ thống xử lý và điều khiển thông tin, cơ sở dữ liệu, phương tiện điện tử;
 - b) **Gây cản trở, rối loạn, làm tê liệt, gián đoạn, ngưng trệ hoạt động**, ngăn chặn trái phép việc truyền đưa dữ liệu của mạng viễn thông, mạng Internet, mạng máy tính, hệ thống thông tin, hệ thống xử lý và điều khiển thông tin, phương tiện điện tử;
 - c) **Xâm nhập, làm tổn hại, chiếm đoạt dữ liệu được lưu trữ, truyền đưa qua mạng** viễn thông, mạng Internet, mạng máy tính, hệ thống thông tin, hệ thống xử lý và điều khiển thông tin, cơ sở dữ liệu, phương tiện điện tử;
 - d) **Xâm nhập, tạo ra hoặc khai thác điểm yếu, lỗ hổng bảo mật** và dịch vụ hệ thống để chiếm đoạt thông tin, thu lợi bất chính;
 - đ) **Sản xuất, mua bán, trao đổi, tặng cho công cụ, thiết bị, phần mềm có tính năng tấn công mạng** viễn thông, mạng Internet, mạng máy tính, hệ thống thông tin, hệ thống xử lý và điều khiển thông tin, cơ sở dữ liệu, phương tiện điện tử để sử dụng vào mục đích trái pháp luật;

Luật An ninh mạng

Điều 29. Bảo vệ trẻ em trên không gian mạng

1. Trẻ em **có quyền được bảo vệ**, tiếp cận thông tin, tham gia hoạt động xã hội, vui chơi, giải trí, giữ bí mật cá nhân, đời sống riêng tư và các quyền khác khi tham gia trên không gian mạng.
2. Cơ quan, tổ chức, cá nhân tham gia hoạt động trên không gian mạng có **trách nhiệm phối hợp với cơ quan có thẩm quyền trong bảo đảm quyền của trẻ em trên không gian mạng**, ngăn chặn thông tin có nội dung gây nguy hại cho trẻ em theo quy định của Luật này và pháp luật về trẻ em.
3. Cơ quan, tổ chức, **cha mẹ, giáo viên, người chăm sóc trẻ em** và cá nhân khác liên quan **có trách nhiệm bảo đảm quyền của trẻ em, bảo vệ trẻ em khi tham gia không gian mạng** theo quy định của pháp luật về trẻ em.

Luật An ninh mạng

Điều 42. Trách nhiệm của cơ quan, tổ chức, cá nhân sử dụng không gian mạng

1. **Kịp thời cung cấp thông tin** liên quan đến bảo vệ an ninh mạng, nguy cơ đe dọa an ninh mạng, hành vi xâm phạm an ninh mạng cho cơ quan có thẩm quyền, lực lượng bảo vệ an ninh mạng.
2. **Thực hiện theo yêu cầu và hướng dẫn của cơ quan có thẩm quyền** trong bảo vệ an ninh mạng; giúp đỡ, tạo điều kiện cho cơ quan, tổ chức và người có trách nhiệm tiến hành các biện pháp bảo vệ an ninh mạng.

Ghi nhớ

Tổ chức, cá nhân **không được xâm phạm ATTTM** của tổ chức, cá nhân khác, tuân thủ pháp luật về an toàn thông tin mạng và an ninh mạng

Ghi nhớ

Các hành vi bị cấm:

1. Đối với người sử dụng:

- a) Đăng tải, phát tán thông tin trái pháp luật, sai sự thật hoặc xóa, thay đổi, làm sai lệch thông tin trên mạng;
- b) Tấn công, vô hiệu hệ thống bảo vệ, chiếm quyền, phá hoại, cản trở hoạt động của HTTT
- c) Phát tán thư rác, phần mềm độc hại, lập HTTT giả mạo, lừa đảo
- d) Thu thập, sử dụng, phát tán, kinh doanh thông tin cá nhân người khác
- e) Xâm nhập mật mã và thông tin đã mã hóa
- f) Tổ chức đánh bạc hoặc đánh bạc qua mạng Internet;
- g) Trộm, mua-bán, thu thập, trao đổi trái phép thông tin thẻ tín dụng, tài khoản ngân hàng của người khác; phát hành, cung cấp, sử dụng trái phép các phương tiện thanh toán;
- h) Giới thiệu, quảng cáo, mua bán hàng hóa, dịch vụ thuộc danh mục cấm theo quy định của pháp luật
- i) Hướng dẫn, xúi giục, lôi kéo, kích động người khác vi phạm pháp luật;
- j) Xuyên tạc lịch sử, xúc phạm tôn giáo, phân biệt đối xử về giới - chủng tộc

Ghi nhớ

Các hành vi bị cấm:

2. Tấn công mạng, khủng bố mạng, gián điệp mạng, tội phạm mạng; gây sự cố, tấn công, xâm nhập, chiếm quyền điều khiển, làm sai lệch, gián đoạn, ngưng trệ, tê liệt hoặc phá hoại hệ thống thông tin quan trọng về an ninh quốc gia.
3. Sản xuất, đưa vào sử dụng công cụ, phương tiện, phần mềm gây cản trở, rối loạn hoạt động của mạng viễn thông, mạng Internet, mạng máy tính, hệ thống thông tin; phát tán chương trình tin học gây hại trên mạng; xâm nhập trái phép vào cơ sở dữ liệu của người khác.
4. Lợi dụng hoặc lạm dụng hoạt động bảo vệ an ninh mạng để xâm phạm các cơ quan, tổ chức, cá nhân.

Luật An ninh mạng 2025

Điều 4. Nguyên tắc bảo vệ an ninh mạng

1. Tuân thủ Hiến pháp & pháp luật; bảo đảm an ninh, chủ quyền, và lợi ích quốc gia trên KGM
2. Dưới sự lãnh đạo của Đảng Cộng sản Việt Nam; sự quản lý thống nhất của Nhà nước; huy động sức mạnh tổng hợp của hệ thống chính trị và toàn dân tộc; phát huy vai trò nòng cốt của lực lượng chuyên trách bảo vệ ANM
3. Kết hợp chặt chẽ giữa bảo vệ ANM với phát triển kinh tế xã hội, bảo đảm quyền con người, quyền công dân, bảo vệ dữ liệu cá nhân; tạo điều kiện hoạt động hợp pháp trên không gian mạng

Luật An ninh mạng 2025

Điều 4. Nguyên tắc bảo vệ an ninh mạng (tiếp)

4. Áp dụng các biện pháp để bảo vệ KGM quốc gia; chủ động phòng ngừa, phát hiện, ngăn chặn, đấu tranh làm thất bại mọi hoạt động trên KGM xâm phạm an ninh quốc gia, trật tự an toàn xã hội, quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân; xử lý kịp thời, nghiêm minh các hành vi vi phạm pháp luật về ANM
5. Triển khai các hoạt động bảo vệ ANM thường xuyên, liên tục đối với cơ sở hạ tầng KGM quốc gia; chủ động áp dụng các biện pháp bảo vệ HTTT quan trọng về an ninh quốc gia

Luật An ninh mạng 2025

Điều 5. Biện pháp bảo vệ an ninh mạng

- Thẩm định ANM
- Đánh giá điều kiện ANM
- Kiểm tra ANM
- Giám sát ANM
- Ứng phó, khắc phục sự cố ANM
- Đấu tranh bảo vệ ANM
- Sử dụng mật mã để bảo vệ ANM
- Sử dụng giải pháp kỹ thuật để bảo vệ ANTTM, AN dữ liệu, HTTT; ngăn chặn thông tin vi phạm pháp luật

Luật An ninh mạng 2025

Điều 5. Biện pháp bảo vệ an ninh mạng (tiếp)

- Ngăn chặn, yêu cầu tạm ngừng, ngừng cung cấp TTM; đình chỉ, tạm đình chỉ các hoạt động thiết lập, cung cấp và sử dụng mạng viễn thông, mạng Internet, sản xuất và sử dụng thiết bị phát, thu phát sóng vô tuyến theo quy định của pháp luật;
- Yêu cầu xóa bỏ, truy cập xóa bỏ TT trái pháp luật hoặc TT sai sự thật, tin giả trên KGM xâm phạm AN quốc gia, trật tự an toàn xã hội, quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân trên KGM
- Thu thập dữ liệu điện tử liên quan đến hoạt động xâm phạm AN quốc gia, TT-ATXH, quyền và lợi ích hợp pháp của cơ quan, tổ chức, cá nhân trên KGM

Luật An ninh mạng 2025

Điều 5. Biện pháp bảo vệ an ninh mạng *(tiếp)*

- Phong tỏa, hạn chế hoạt động của HTTT; đình chỉ, tạm đình chỉ hoặc yêu cầu ngừng hoạt động của HTTT, thu hồi tên miền theo quy định của pháp luật
- Khởi tố, điều tra, truy tố, xét xử theo quy định của Bộ luật Tố tụng hình sự
- Biện pháp khác theo quy định của pháp luật về AN quốc gia, pháp luật về xử lý vi phạm hành chính

Chính phủ quy định chi tiết nội dung, trình tự, thủ tục, thẩm quyền áp dụng các biện pháp bảo vệ ANM, trừ biện pháp quy định tại 2 điểm cuối ở trên.

Luật An ninh mạng 2025

Điều 6. Hợp tác quốc tế về an ninh mạng

Điều 7. Các hành vi bị nghiêm cấm về ANM (cần đọc thêm)

Điều 8. Phân loại cấp độ HTTT

Điều 9. HTTT quan trọng về AN quốc gia

Điều 10. Nhiệm vụ, biện pháp bảo vệ ANM đối với HTTT

Điều 11. Trách nhiệm bảo vệ ANM đối với HTTT quan trọng quốc gia

Điều 12. Kiểm tra ANM đối với HTTT của cơ quan, tổ chức không thuộc danh mục HTTT quan trọng về AN quốc gia

Điều 13. Các TT và hành vi sử dụng CNTT, phương tiện điện tử xâm phạm AN quốc gia, TT-ATXH trên KGM

Điều 14. Phòng ngừa, xử lý TT và hành vi sử dụng CNTT, phương tiện điện tử xâm phạm AN quốc gia, TT-ATXH trên KGM

Luật An ninh mạng 2025

Điều 15. Phòng, chống gián điệp mạng; bảo vệ TT thuộc bí mật nhà nước, bí mật công tác, bí mật kinh doanh, bí mật cá nhân, bí mật gia đình và đời sống riêng tư trên KGM

Điều 16. Phòng, chống xâm hại trẻ em trên KGM

Điều 17. Phòng ngừa, phát hiện, ngăn chặn và xử lý phần mềm độc hại

Điều 18. Phòng, chống tấn công mạng

Điều 19. Phòng, chống khủng bố mạng

Điều 20. Phòng ngừa, xử lý tình huống nguy hiểm về ANM

Điều 21. Đấu tranh bảo vệ ANM

Điều 22. Ngăn chặn xung đột thông tin trên KGM

Luật An ninh mạng 2025

Chương IV – hoạt động bảo vệ ANM, từ Điều 23 - Điều 26

Chương V – Tiêu chuẩn, Quy chuẩn kỹ thuật, sản phẩm, dịch vụ ANM, từ Điều 27 - Điều 29

Chương VI – Lực lượng, điều kiện bảo đảm ANM, từ Điều 30 - Điều 38

Chương VII – Trách nhiệm của cơ quan, tổ chức, cá nhân về ANM, từ Điều 39 - Điều 42

Luật An ninh mạng 2025

Điều 28. Sản phẩm, dịch vụ ANM

- **Sản phẩm ANM:**
 - + SP mật mã dân sự
 - + SP Kiểm tra, đánh giá ANM
 - + SP giám sát ANM
 - + SP chống tấn công, xâm nhập
 - + SP ANM khác

Luật An ninh mạng 2025

Điều 28. Sản phẩm, dịch vụ ANM (tiếp)

- **Dịch vụ ANM:**

- + DV kiểm tra, đánh giá ANM
- + DV bảo mật thông tin không sử dụng mật mã dân sự
- + DV mật mã dân sự
- + DV tư vấn ANM
- + DV giám sát ANM
- + DV ứng cứu sự cố ANM
- + DV khôi phục dữ liệu
- + DV phòng ngừa, chống tấn công mạng
- + Dịch vụ ANM khác

Đạo đức trong ATTT

- Sinh viên ngành an toàn thông tin không được kỳ vọng sẽ học đạo đức trong môi trường lý thuyết mà học trong khuôn khổ rộng và thực tế hơn.
- Các chuyên gia ATTT có thể được mong đợi sẽ được cung cấp thông tin về tính đạo đức nhiều hơn những người khác trong tổ chức và họ thường phải chịu được mức độ giám sát cao hơn.
- Đánh giá cho người làm ATTT cần bổ sung yếu tố đạo đức, định nghĩa hành vi được chấp nhận và không được chấp nhận.

Đạo đức trong ATTT

- Một số tiêu chuẩn hoặc cách tiếp cận đạo đức
 - *Phương pháp tiếp cận không theo chủ nghĩa*: một hành động có đạo đức là hành động mang lại lợi ích tốt nhất hoặc ít tổn hại nhất
 - *Cách tiếp cận về quyền*: hành động có đạo đức là hành động bảo vệ và tôn trọng tốt nhất các quyền nhân thân của những người bị ảnh hưởng bởi hành động đó. Các quyền nhân thân thường là quyền tự lựa chọn cuộc sống của mình, quyền được nói sự thật, quyền không bị thương và quyền được bảo mật ở một mức độ nào đó. Những quyền này bao hàm một số nghĩa vụ nhất định - cụ thể là nghĩa vụ tôn trọng quyền của người khác.

Đạo đức trong ATTT

- Một số tiêu chuẩn hoặc cách tiếp cận đạo đức
 - *Phương pháp tiếp cận công bằng*: định nghĩa các hành động đạo đức là những hành động có kết quả coi tất cả con người như nhau, hoặc kết hợp mức độ công bằng dựa trên một số tiêu chuẩn có thể bảo vệ được, thường được mô tả là một "sân chơi bình đẳng."
 - *Cách tiếp cận tốt chung*: lập luận rằng các mối quan hệ phức tạp được tìm thấy trong một xã hội là cơ sở của một quá trình dựa trên lý luận đạo đức tôn trọng và có lòng trắc ẩn đối với tất cả những người khác, đặc biệt là những thành viên dễ bị tổn thương nhất trong xã hội. Cách tiếp cận này có xu hướng tập trung vào phúc lợi chung.

Đạo đức trong ATTT

- Một số tiêu chuẩn hoặc cách tiếp cận đạo đức
 - *Phương pháp tiếp cận đạo đức*: Trong hầu hết các khuôn khổ đạo đức dựa trên đạo đức, các đức tính bao gồm trung thực, dũng cảm, từ bi, rộng lượng, khoan dung, yêu thương, trung thành, chính trực, công bằng, tự chủ và thận trọng. Đạo đức nhân đức yêu cầu tất cả mọi người cân nhắc xem liệu kết quả của bất kỳ quyết định cụ thể nào sẽ phản ánh tốt nhận thức của họ và của người khác về họ.

Đạo đức trong ATTT

10 điều răn của đạo đức máy tính:

(nguồn Computer Professionals for Social Responsibility)

1. Bạn không được sử dụng máy tính để làm hại người khác.
2. Bạn không được can thiệp vào công việc máy tính của người khác.
3. Bạn không được rình mò các tập tin máy tính của người khác.
4. Bạn không được dùng máy vi tính để ăn trộm.
5. Bạn không được sử dụng máy vi tính để làm chứng dối.

Đạo đức trong ATTT

10 điều răn của đạo đức máy tính:

(nguồn Computer Professionals for Social Responsibility)

6. Bạn không được sao chép hoặc sử dụng phần mềm độc quyền mà bạn chưa trả tiền.
7. Bạn không được sử dụng tài nguyên máy tính của người khác mà không được phép hoặc bồi thường thích đáng.
8. Bạn không được chiếm đoạt tài sản trí tuệ của người khác.
9. Bạn nên nghĩ về những hậu quả xã hội của chương trình bạn đang viết hoặc hệ thống bạn đang thiết kế.
10. Bạn phải luôn sử dụng máy tính theo những cách đảm bảo sự cân nhắc và tôn trọng đối với đồng loại của bạn.

Đạo đức và Giáo dục

- Nhân viên phải được đào tạo và cập nhật về các chủ đề của ATTT, bao gồm các hành vi mong đợi của một nhân viên có đạo đức. Điều này đặc biệt quan trọng trong các lĩnh vực bảo mật thông tin, vì nhiều nhân viên có thể không được đào tạo kỹ thuật chính thức để hiểu rằng hành vi của họ là phi đạo đức hoặc thậm chí là bất hợp pháp.
- Sử dụng các tình huống thực tế để giới thiệu cho nhân viên và các bên liên quan khác suy nghĩ về đạo đức và có các lựa chọn đạo đức
- Giáo dục, đào tạo và nhận thức đúng đắn về đạo đức và pháp luật là rất quan trọng để tạo ra một người sử dụng hệ thống có thông tin, được chuẩn bị tốt và có rủi ro thấp.

Ngăn chặn hành vi phi đạo đức và bất hợp pháp

- Nhân viên ATTT có trách nhiệm ngăn chặn các hành vi phi đạo đức và bất hợp pháp, sử dụng chính sách, giáo dục và đào tạo và công nghệ làm biện pháp kiểm soát hoặc biện pháp bảo vệ, để bảo vệ thông tin và hệ thống của tổ chức.

Ngăn chặn hành vi phi đạo đức và bất hợp pháp

Răn đe là phương pháp tốt nhất để ngăn chặn một hoạt động bất hợp pháp hoặc phi đạo đức.

1. Sợ bị phạt: khiển trách không chính thức hoặc cảnh cáo bằng lời nói có thể không có tác động tương tự như đe dọa bị thôi việc, bỏ tù, hoặc bị mất lương.
2. Khả năng bị bắt: Phải có khả năng cao là thủ phạm của các hành vi bất hợp pháp hoặc phi đạo đức sẽ bị bắt.
3. Xác suất của hình phạt được thực hiện: Tổ chức phải sẵn sàng và có khả năng thực hiện hình phạt.

Nếu thiếu một trong các tiêu chí này, nhân viên sẽ không tôn trọng hoặc không tuân theo các chính sách.

Bộ Quy tắc Ứng xử trên mạng xã hội

Quyết định số 874/QĐ-BTTTT ngày 17/6/2021 của Bộ Thông tin và Truyền thông.

Đ1 Mục đích

1. Tạo điều kiện phát triển lành mạnh mạng xã hội tại Việt Nam, đảm bảo quyền tự do cá nhân, quyền tự do kinh doanh, không phân biệt đối xử nhà cung cấp dịch vụ trong và ngoài nước, phù hợp với chuẩn mực, thông lệ và các điều ước quốc tế mà Việt Nam đã tham gia;
2. Xây dựng chuẩn mực đạo đức về hành vi, ứng xử trên mạng xã hội, giáo dục ý thức, tạo thói quen tích cực trong các hành vi ứng xử của người dùng trên mạng xã hội, góp phần xây dựng môi trường mạng an toàn, lành mạnh tại Việt Nam.

Bộ Quy tắc Ứng xử trên mạng xã hội

Đ3 Quy tắc ứng xử chung

1. Quy tắc Tôn trọng, tuân thủ pháp luật: Tuân thủ pháp luật Việt Nam, tôn trọng quyền và lợi ích hợp pháp của tổ chức, cá nhân.
2. Quy tắc Lành mạnh: Hành vi, ứng xử trên mạng xã hội phù hợp với các giá trị đạo đức, văn hóa, truyền thống tốt đẹp của dân tộc Việt Nam.
3. Quy tắc An toàn, bảo mật thông tin: Tuân thủ các quy định và hướng dẫn về bảo vệ an toàn và bảo mật thông tin.
4. Quy tắc Trách nhiệm: Chịu trách nhiệm về các hành vi, ứng xử trên mạng xã hội; phối hợp với các cơ quan chức năng để xử lý hành vi, nội dung thông tin vi phạm pháp luật.

Bộ Quy tắc Ứng xử trên mạng xã hội

Đ4 Quy tắc ứng xử cho tổ chức, cá nhân

1. Tìm hiểu và tuân thủ các điều khoản hướng dẫn sử dụng của nhà cung cấp dịch vụ mạng xã hội trước khi đăng ký, tham gia mạng xã hội.
2. Nên sử dụng họ, tên thật cá nhân, tên hiệu thật của tổ chức, cơ quan và đăng ký với nhà cung cấp dịch vụ để xác thực tên hiệu, địa chỉ trang mạng, đầu mối liên lạc khi tham gia, sử dụng mạng xã hội.
3. Thực hiện biện pháp tự quản lý, bảo mật tài khoản mạng xã hội và nhanh chóng thông báo tới các cơ quan chức năng, nhà cung cấp dịch vụ khi tài khoản tổ chức, cá nhân bị mất quyền kiểm soát, bị giả mạo, lợi dụng và sử dụng vào mục đích không lành mạnh, ảnh hưởng đến an ninh quốc gia và trật tự an toàn xã hội, ảnh hưởng đến quyền và lợi ích hợp pháp của tổ chức, cá nhân.
4. Chia sẻ những thông tin có nguồn chính thống, đáng tin cậy.

Bộ Quy tắc Ứng xử trên mạng xã hội

Đ4 Quy tắc ứng xử cho tổ chức, cá nhân

5. Có các hành vi, ứng xử phù hợp với những giá trị đạo đức, văn hóa, truyền thống của dân tộc Việt Nam; không sử dụng từ ngữ gây thù hận, kích động bạo lực, phân biệt vùng miền, giới tính, tôn giáo.
6. Không đăng tải những nội dung vi phạm pháp luật, các thông tin xúc phạm danh dự, nhân phẩm ảnh hưởng đến quyền và lợi ích hợp pháp của các tổ chức, cá nhân khác; sử dụng ngôn ngữ phản cảm, vi phạm thuần phong mỹ tục; tung tin giả, tin sai sự thật; quảng cáo, kinh doanh dịch vụ trái phép... gây bức xúc trong dư luận xã hội, ảnh hưởng đến trật tự an toàn xã hội.
7. Khuyến khích sử dụng mạng xã hội để tuyên truyền, quảng bá về đất nước - con người, văn hóa tốt đẹp của Việt Nam, chia sẻ thông tin tích cực, những tấm gương người tốt, việc tốt.
8. Vận động người thân trong gia đình, bạn bè, những người xung quanh tham gia giáo dục, bảo vệ trẻ em, trẻ vị thành niên sử dụng mạng xã hội một cách an toàn, lành mạnh.

Bộ Quy tắc Ứng xử trên mạng xã hội

Đ5 Quy tắc ứng xử cho cán bộ, công chức, viên chức và người lao động trong cơ quan nhà nước

1. Cán bộ, công chức, viên chức và người lao động trong cơ quan nhà nước thực hiện nội dung quy định tại Điều 4 của Bộ Quy tắc này.
2. Thực hiện nội quy của cơ quan, tổ chức về việc cung cấp thông tin lên mạng xã hội.
3. Thông báo tới cơ quan chủ quản để kịp thời có hướng xử lý, trả lời, giải quyết khi có những ý kiến, thông tin trái chiều, thông tin vi phạm pháp luật có liên quan đến chức năng, nhiệm vụ, quyền hạn, lĩnh vực quản lý của cán bộ, công chức, viên chức và người lao động.

Bộ Quy tắc Ứng xử trên mạng xã hội

Đ6 Quy tắc ứng xử cho các cơ quan nhà nước

1. Thực hiện nội dung quy định cho cơ quan, tổ chức nêu tại Điều 4 của Bộ Quy tắc này.
2. Có trách nhiệm quản lý, bảo mật tài khoản mạng xã hội và nhanh chóng thông báo tới nhà cung cấp dịch vụ khi tài khoản của cơ quan, tổ chức bị mất quyền kiểm soát hoặc bị giả mạo.
3. Cung cấp thông tin trên mạng xã hội đồng bộ, thống nhất với thông tin đã được cung cấp trên các phương tiện truyền thông chính thống khác.
4. Nên có phản hồi những ý kiến trên mạng xã hội về vấn đề liên quan đến chức năng, nhiệm vụ và quyền hạn của cơ quan, tổ chức mình.

Bộ Quy tắc Ứng xử trên mạng xã hội

Đ7 Quy tắc ứng xử cho các nhà cung cấp dịch vụ mạng xã hội

1. Công bố rõ ràng các điều khoản sử dụng dịch vụ, bao gồm tất cả các quyền và nghĩa vụ của nhà cung cấp dịch vụ và người sử dụng.
2. Ban hành và công khai các biện pháp phát hiện, thông báo và phối hợp với các cơ quan chức năng để xử lý, ngăn chặn và loại bỏ các nội dung thông tin vi phạm bản quyền, vi phạm pháp luật.
3. Khi nhận được thông báo yêu cầu loại bỏ các thông tin vi phạm bản quyền, vi phạm pháp luật từ cơ quan chức năng có thẩm quyền, nhà cung cấp dịch vụ mạng xã hội phối hợp với tổ chức, cá nhân sử dụng mạng xã hội để xử lý theo các quy định của pháp luật Việt Nam.

Bộ Quy tắc Ứng xử trên mạng xã hội

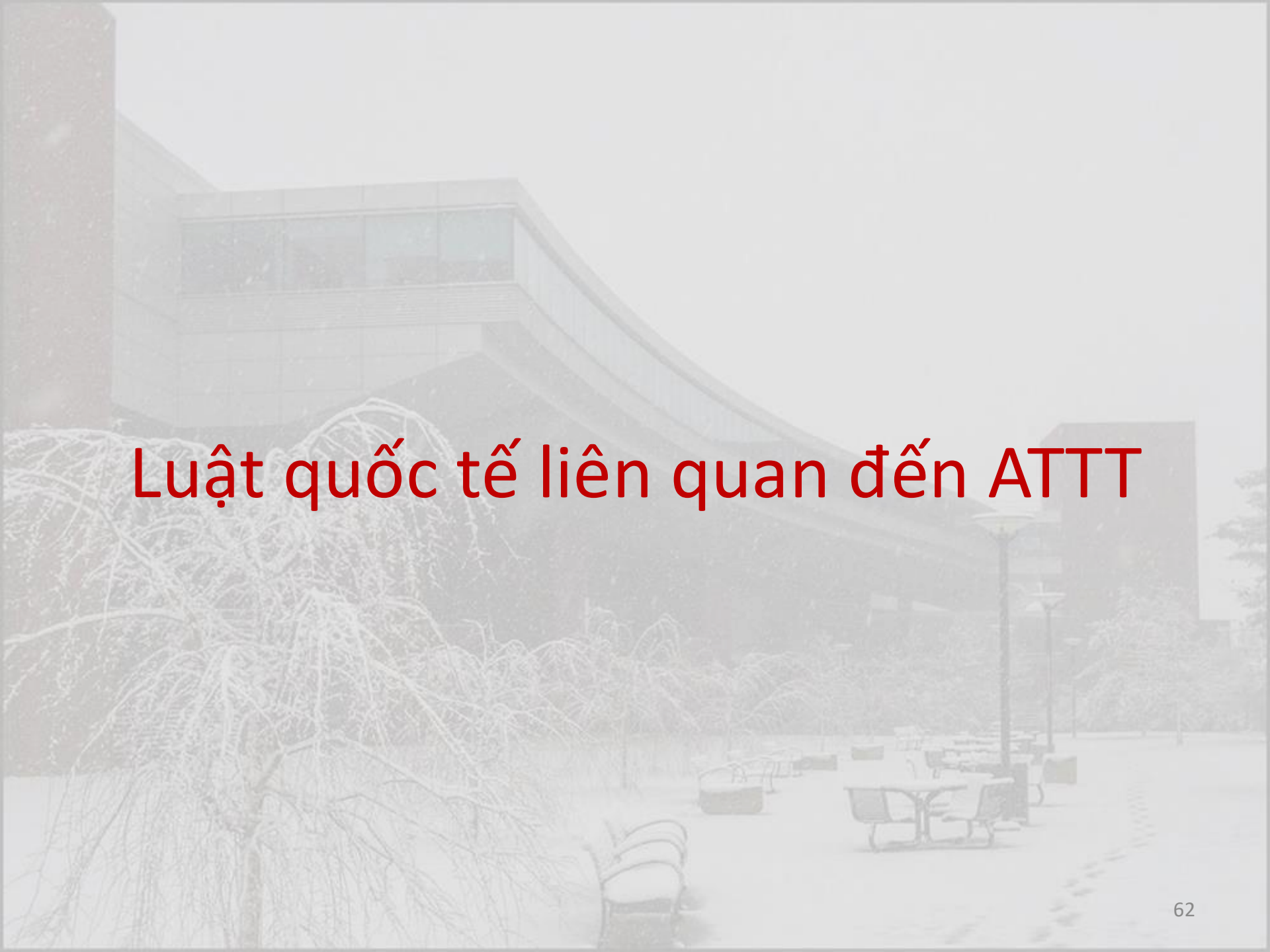
Đ7 Quy tắc ứng xử cho các nhà cung cấp dịch vụ mạng xã hội

4. Hướng dẫn người sử dụng mạng xã hội, hỗ trợ và bảo vệ quyền, lợi ích hợp pháp của “người yếu thế” trong xã hội (người nghèo, người dân tộc thiểu số, trẻ em, trẻ vị thành niên, người khuyết tật...) sử dụng mạng xã hội an toàn, lành mạnh nhằm tránh bị khai thác, lạm dụng, bạo lực về tinh thần trên mạng xã hội; có biện pháp để bảo đảm sự an toàn và phát triển lành mạnh của trẻ em, trẻ vị thành niên trên mạng xã hội theo quy định của pháp luật Việt Nam.
5. Tôn trọng quyền được bảo vệ thông tin của người sử dụng, không thu thập thông tin cá nhân và cung cấp thông tin của người sử dụng dịch vụ cho bên thứ ba khi chưa được sự cho phép của chủ thể thông tin.

Bộ Quy tắc Ứng xử trên mạng xã hội

Đ8 Triển khai và thực hiện

1. Khuyến nghị các cơ quan, tổ chức căn cứ vào các văn bản quy phạm pháp luật hiện hành và Bộ Quy tắc này triển khai thực hiện và phổ biến nội dung của Bộ Quy tắc phù hợp với chức năng, nhiệm vụ, quyền hạn và đặc thù của cơ quan, tổ chức của mình, trong đó chú trọng đến việc bảo đảm an toàn, lành mạnh cho “người yếu thế” khi sử dụng mạng xã hội.
2. Người sử dụng và nhà cung cấp dịch vụ mạng xã hội được khuyến khích thực hiện đầy đủ các nội dung Bộ Quy tắc và tuyên truyền, phổ biến rộng rãi tới các tổ chức, cá nhân khác sử dụng mạng xã hội.

The background of the slide features a faded, grayscale image of a modern architectural structure with a curved facade and large glass windows. In the foreground, a large, leafless weeping willow tree is visible on the left side. The overall scene is misty or foggy, creating a soft, atmospheric effect.

Luật quốc tế liên quan đến ATTT

Các loại Luật tại Hoa Kỳ

- Hiến pháp — Bắt nguồn từ Hiến pháp Hoa Kỳ, hiến pháp tiểu bang hoặc hiến pháp địa phương, luật hoặc hiến chương
- Luật theo luật định — Bắt nguồn từ một nhánh lập pháp có nhiệm vụ đặc biệt với việc tạo ra và xuất bản các luật và quy chế
- Luật quản lý hoặc hành chính — Có nguồn gốc từ chi nhánh hành pháp hoặc cơ quan quản lý được ủy quyền và bao gồm các lệnh và quy định hành pháp
- Thông luật, án lệ và tiền lệ — Bắt nguồn từ nhánh tư pháp hoặc ban giám sát và liên quan đến việc giải thích luật dựa trên các hành động của tòa án trước đó và / hoặc cấp cao hơn

Các loại Luật tại Hoa Kỳ (tiếp)

3 nhóm luật chính tại Hoa Kỳ:

- Luật dân sự bao gồm nhiều loại luật liên quan đến các mối quan hệ giữa và giữa các cá nhân và tổ chức
 - Bao gồm luật hợp đồng, luật lao động, luật gia đình và luật tra tấn (Tort Law)
 - Luật tra tấn là tập hợp con của luật dân sự cho phép các cá nhân tìm cách khắc phục trong trường hợp bị thương về cá nhân, thể chất hoặc tài chính
- Luật hình sự giải quyết các vi phạm có hại cho xã hội; được “tích cực” thực thi và truy tố bởi nhà nước
 - Luật hình sự giải quyết các quy chế liên quan đến luật giao thông, trật tự công cộng, thiệt hại tài sản và thiệt hại cá nhân
- Luật hành chính Luật hành chính được công bố trong Bộ luật Quy định Liên bang (CFR - Code of Federal Regulations) là các chủ đề và các thủ tục được thực thi trong các cơ quan liên bang để thực hiện các luật được Quốc hội thông qua. Luật Hành chính phải tuân thủ tất cả các luật hình sự và dân sự hiện hành, tuân thủ Hiến pháp Hoa kỳ

Các loại Luật tại Hoa Kỳ (tiếp)

- Luật riêng tư (Private Law) được coi là một tập con của luật dân sự, điều chỉnh các mối quan hệ giữa các cá nhân cũng như các mối quan hệ giữa cá nhân và tổ chức
 - Luật riêng tư bao trùm lên luật gia đình, luật thương mại và luật lao động
- Luật công (Public Law) điều chỉnh cấu trúc và quản trị của các cơ quan chính phủ và các mối quan hệ của họ với công dân, nhân viên và các chính phủ khác
 - Luật công bao gồm luật hình sự, luật hành chính và luật hiến pháp

Các Luật liên quan đến CNTT

- Về tội phạm máy tính
 - Luật lạm dụng và gian lận máy tính CFAA (Computer Fraud and Abuse Act)
 - Luật bảo vệ hạ tầng thông tin quốc gia (National Information Infrastructure Protection Act) 1996
 - Hướng dẫn kết án Liên bang (Federal Sentencing Guidelines) 1991
 - Luật quản lý bảo mật thông tin Liên bang FISMA (Federal Information Security Management Act) 2002
 - Luật Bảo mật không gian mạng Liên bang (Federal Cybersecurity Laws) 2014

Các Luật liên quan đến CNTT

- Về Tài sản trí tuệ
 - Luật bản quyền và Bản quyền số Thiên niên kỷ (Copyright and the Digital Millennium Copyright Act)
 - Nhãn hiệu (Trademarks)
 - Bằng sáng chế (Patents)
 - Bí mật thương mại (Trade Secrets)
 - Giấy phép (Licensing)

Các Luật liên quan đến CNTT

- Về Xuất/Nhập khẩu
 - Luật xuất khẩu và Gián điệp (Export and Espionage Laws): bảo vệ sở hữu trí tuệ và lợi thế cạnh tranh bằng Đạo luật Gián điệp Kinh tế EEA (Economic Espionage Act) 1996
 - Đạo luật An ninh và Tự do qua Mã hóa (Security and Freedom through Encryption Act) năm 1997 cung cấp hướng dẫn về việc sử dụng mã hóa và đưa ra các biện pháp bảo vệ công chúng khỏi sự can thiệp của chính phủ.

Luật quyền riêng tư - Privacy Laws

- Nhiều tổ chức thu thập, kinh doanh và bán thông tin cá nhân như một loại hàng hóa, và nhiều cá nhân tìm đến chính phủ để bảo vệ quyền riêng tư của họ
- Ngày nay, việc tổng hợp thông tin (aggregation) từ nhiều nguồn cho phép các tổ chức phi đạo đức xây dựng cơ sở dữ liệu đáng báo động số lượng thông tin cá nhân
- Sự riêng tư trong bối cảnh này không phải là tự do sự quan sát mà đúng hơn, nó là “trạng thái không bị xâm nhập trái phép”

Luật quyền riêng tư - Privacy Laws

- Đạo luật về quyền riêng tư của Liên bang (Federal Privacy Act) năm 1974 quy định việc sử dụng thông tin cá nhân của chính phủ và được tạo ra để đảm bảo rằng các cơ quan chính phủ bảo vệ quyền riêng tư của thông tin cá nhân và doanh nghiệp, đồng thời buộc họ phải chịu trách nhiệm nếu bất kỳ phần nào của thông tin này được tiết lộ mà không được phép
- Đạo luật về quyền riêng tư trong truyền thông điện tử (ECPA - Electronic Communications Privacy Act) năm 1986 là một tập hợp các đạo luật quy định việc ngăn chặn thông tin liên lạc bằng dây, điện tử và bằng miệng
- Các đạo luật này kết hợp với Hiến pháp Hoa Kỳ sửa đổi lần thứ tư, cấm khám xét và thu giữ mà không có lệnh

Luật quyền riêng tư - Privacy Laws

- Đạo luật về trách nhiệm giải trình và cung cấp bảo hiểm y tế HIPAA (The Health Insurance Portability & Accountability Act) năm 1996: bảo vệ tính bí mật và bảo mật của dữ liệu chăm sóc sức khỏe
- HIPAA yêu cầu các tổ chức lưu giữ thông tin chăm sóc sức khỏe để sử dụng các cơ chế an toàn thông tin để bảo vệ thông tin này, cũng như các chính sách và thủ tục để duy trì chúng.
- Nó cũng yêu cầu đánh giá toàn diện về hệ thống, chính sách và thủ tục an toàn thông tin của tổ chức
- HIPAA cung cấp hướng dẫn sử dụng chữ ký điện tử dựa trên các tiêu chuẩn bảo mật đảm bảo tính toàn vẹn của thông điệp, xác thực người dùng và chống chối bỏ (nonrepudiation)

PCI DSS

- Tiêu chuẩn bảo mật dữ liệu ngành thẻ thanh toán PCI DSS (Payment Card Industry Data Security Standard) là một tập hợp các tiêu chuẩn công nghiệp bắt buộc đối với bất kỳ tổ chức nào xử lý thẻ tín dụng, thẻ ghi nợ và thẻ thanh toán đặc biệt trong nỗ lực giảm gian lận thẻ tín dụng
- Tiêu chuẩn hiện hành (4.0) được trình bày bởi Hội đồng Tiêu chuẩn Bảo mật PCI khi tập trung vào 12 yêu cầu trong sáu lĩnh vực:

PCI DSS

- Phát triển, duy trì mạng và hệ thống bảo mật
 1. Cài đặt và vận hành tường lửa (bảo vệ dữ liệu chủ thẻ)
 2. Sửa đổi cấu hình và mật khẩu hệ thống mặc định
- Bảo vệ dữ liệu chủ thẻ
 3. Bảo vệ chung cho việc lưu trữ dữ liệu chủ thẻ
 4. Sử dụng mã hóa khi truyền dữ liệu chủ thẻ dữ liệu trên các mạng công cộng
- Duy trì chương trình quản lý lỗ hổng
 5. Sử dụng bảo vệ chống phần mềm độc hại và chống vi-rút được duy trì và cập nhật
 6. Phát triển và duy trì bảo mật hệ thống và ứng dụng

PCI DSS

- Thực hiện biện pháp kiểm soát truy cập mạnh
 7. Sử dụng các biện pháp kiểm soát truy cập need-to-know đối với dữ liệu chủ thẻ
 8. Kiểm soát truy cập chính thức cho các thành phần hệ thống nhấn mạnh quy trình xác thực và nhận dạng hiệu quả
 9. Quản lý bảo mật vật lý đối với quyền truy cập dữ liệu của chủ thẻ
- Giám sát và Kiểm tra mạng
 10. Tài nguyên mạng và dữ liệu chủ thẻ được giám sát, theo dõi và kiểm toán
 11. Hệ thống và quy trình bảo mật được kiểm tra định kỳ
- Duy trì chính sách bảo mật thông tin
 12. Chính sách bảo mật thông tin hiệu quả và toàn diện được phát triển và triển khai cho tất cả nhân viên

PCI DSS

- Những lợi ích của việc tuân thủ PCI DSS, do Hội đồng Tiêu chuẩn Bảo mật PCI thúc đẩy, bao gồm:
 - Khẳng định rằng hệ thống xử lý thẻ thanh toán là an toàn, thúc đẩy sự tin tưởng đối với khách hàng
 - Cải thiện uy tín với các tổ chức phát hành thẻ thanh toán và xử lý thanh toán
 - Phòng chống vi phạm bảo mật
 - Hỗ trợ tuân thủ các tiêu chuẩn bảo mật khác, chẳng hạn như HIPAA, SOX và GLB
 - Hỗ trợ cho các chiến lược bảo mật của tổ chức
 - Tăng hiệu quả của cơ sở hạ tầng thông tin

Công ước về tội phạm mạng Hội đồng Châu Âu - European Council Cybercrime Convention

- Trao quyền cho lực lượng đặc nhiệm quốc tế giám sát một loạt các chức năng bảo mật Internet và chuẩn hóa luật công nghệ trên phạm vi quốc tế.
- Công ước cũng cố gắng nâng cao hiệu quả của các cuộc điều tra quốc tế về vi phạm luật công nghệ.
- Mục tiêu chung của công ước là đơn giản hóa thu thập thông tin cho các cơ quan thực thi pháp luật trong một số loại tội phạm quốc tế, cũng như quy trình dẫn độ

Quy định chung về bảo vệ dữ liệu của Liên minh Châu Âu – General Data Protection Regulation

- Quy định chung về bảo vệ dữ liệu (GDPR – General Data Protection Regulation) có hiệu lực vào năm 2018 nhằm cung cấp một luật duy nhất, hài hòa bao gồm dữ liệu trên toàn Liên minh Châu Âu, củng cố các biện pháp bảo vệ quyền riêng tư cá nhân.
- Quy định mới áp dụng cho tất cả các tổ chức thu thập dữ liệu từ các cư dân EU hoặc xử lý thông tin đó thay mặt cho người thu thập thông tin đó. Điều quan trọng, luật thậm chí còn áp dụng cho các tổ chức không có trụ sở tại EU, nếu họ thu thập thông tin về cư dân EU

Quy định chung về bảo vệ dữ liệu của Liên minh Châu Âu – General Data Protection Regulation

- Các điều khoản chính của GDPR gồm:
 - **Tính hợp pháp, công bằng và minh bạch:** phải có cơ sở pháp lý để xử lý thông tin cá nhân, không được xử lý dữ liệu theo cách gây hiểu lầm hoặc gây bất lợi cho chủ thể dữ liệu, phải công khai và trung thực về các hoạt động xử lý dữ liệu
 - **Giới hạn mục đích:** phải ghi rõ ràng và tiết lộ các mục đích thu thập dữ liệu và chỉ giới hạn hoạt động trong các mục đích được tiết lộ
 - **Giảm thiểu dữ liệu:** phải đảm bảo rằng dữ liệu được xử lý là đầy đủ cho mục đích đã nêu và chỉ giới hạn ở những gì thực sự cần cho mục đích đó
 - **Độ chính xác:** dữ liệu được thu thập, tạo hoặc duy trì là chính xác và không gây hiểu nhầm, các bản ghi được cập nhật, chỉnh sửa hoặc xóa dữ liệu không chính xác

Quy định chung về bảo vệ dữ liệu của Liên minh Châu Âu – General Data Protection Regulation

- Các điều khoản chính của GDPR gồm:
 - **Giới hạn lưu trữ**: chỉ lưu giữ dữ liệu miễn là nó cần thiết để thực hiện mục đích hợp pháp, được tiết lộ và người lưu giữ phải tuân thủ “quyền được quên”, cho phép mọi người yêu cầu công ty xóa thông tin của họ nếu không còn cần thiết
 - **Bảo mật**: phải có các biện pháp kiểm soát tính toàn vẹn và bảo mật thích hợp để bảo vệ dữ liệu
 - **Trách nhiệm giải trình**: phải chịu trách nhiệm về các hành động đã thực hiện với dữ liệu được bảo vệ và phải có khả năng chứng minh sự tuân thủ.

Tội phạm Công nghệ Cao của Úc - Australian High-Tech Crime

- Tội phạm công nghệ cao được định nghĩa và truy tố tại Úc theo luật Khổ tình vượng chung Phần 10.7 — Các vi phạm về máy tính của Đạo luật Bộ luật Hình sự 1995
- Cụ thể luật gồm:
 - xâm nhập hệ thống dữ liệu (chẳng hạn như hack)
 - phá hủy hoặc sửa đổi trái phép dữ liệu
 - các hành động nhằm mục đích từ chối dịch vụ của hệ thống máy tính cho người dùng, chẳng hạn như các cuộc tấn công từ chối dịch vụ (DoS) và các cuộc tấn công từ chối dịch vụ phân tán (DDoS) bằng cách sử dụng botnet the creation and distribution of malicious software
 - việc tạo và phân phối phần mềm độc hại

Bài tập

1. Tìm hiểu các chứng chỉ của (ISC)². Tìm hiểu “CISSP” và tìm hiểu xem chương trình học tập thường xuyên nào là bắt buộc đối với người có CISSP để duy trì trạng thái tốt và hiện hành.
2. Tìm hiểu các lựa chọn nghề nghiệp trong lĩnh vực an toàn thông tin mạng tại Cơ quan An toàn mạng và Bảo mật Hạ tầng Quốc gia Hoa Kỳ (Cybersecurity and Infrastructure Security Agency). CISA tuyển dụng những loại công việc về an toàn thông tin nào? Công việc bạn tìm được yêu cầu những bằng cấp gì?

Bài tập

3. Tìm hiểu các công việc về an toàn thông tin và yêu cầu liên quan của các tổ chức, công ty tại Việt Nam. Những công việc nào có nhiều tổ chức tuyển dụng nhất? Những yêu cầu cần đáp ứng cho 5 công việc phổ biến nhất là gì?
4. Mỗi nhóm hãy tìm hiểu và trình bày bộ quy tắc đạo đức / ứng xử (Codes of Conduct) của 2 trong các hiệp hội và tổ chức sau:
 - (ISC)²
 - SANS
 - ISACA
 - Information Systems Security Association (ISSA)
 - và 1 tổ chức tại Việt Nam.Nhận xét sự khác biệt.

Closing Case

Iris was a little unsure of what to do next. She had just left the meeting with the other executives. At the meeting, they confirmed the need for action on the matter of the critical information offered for sale on a public auction site. That was the last point of agreement. This was a risk they had simply not planned for, and they were completely unprepared. Just before the meeting broke up, they had made assignments to various people in the meeting. Robin, the CEO, was going to contact the members of the board of directors to brief them so that if the story became public they would not be surprised. Jerry, the corporate counsel, was going to start an intensive effort to discover what peer companies had done in situations like this. Mike, the CIO, was assigned to contact the auction site to get the auction shut down and lay the groundwork for working with whatever authorities were brought in for the criminal aspects of the case.

Iris was assigned to research which law enforcement agency should be involved in the investigation. She already knew that the auction site was hosted on a server owned by a company that was not in the United States, where RWW, Inc. was located. She reached for her business card box and began thumbing through the contacts she had.

Discussion Questions

1. Do you think the response of the company so far indicates any flaws in company policy or practices that are revealed in the incident?
2. With which law enforcement agency do you think Iris should consult? On what factors do you base that recommendation?
3. What criminal acts might have occurred in this situation? Considering who the perpetrators might be, what do you think their relationship to RWW, Inc. might be?



Ethical Decision Making

Suppose that Cassandra, the CEO's executive assistant, was involved in the criminal activity of selling company data. Also suppose that when the anonymous tip came in, she deleted the message without bringing it to anyone else's attention. Cassandra's assignment is to delete any and all messages deemed to be "noise" or a nuisance and then bring the remaining messages to the attention of the CEO.

By deleting the message that Iris would have received, is Cassandra's act unethical? Is it illegal?